



Privacy by design in software development - Day 1

Main points to consider

Larisa Gabudeanu – ISM – 2024

Grading laws and regulations (5 points in total)

- 1 point homework (will be available in Moodle after the course; deadline 12 January 2025, 23:00)
- 3 points exam
- 1 point activity in class (quiz on Moodle; group case study)
- **Recap meeting:** before exam

! Please use real name on Zoom/Slack !

Overview of topics

1. Correlation with information security issues
2. Data protection concepts
3. Processing basis for data processing: initial purpose vs. subsequent purposes
4. Controller vs processor
5. Liability sharing
6. Information notices (transparency principle)
7. Data subject rights and retention period
8. Profiling and automated decisions
9. Pseudo-anonymized data

1 of 9: Correlation with information security - OWASP Top 10 risk - Cryptographic Failures

- **Examples**

- Is any data transmitted in clear text? This concerns protocols such as HTTP, SMTP, and FTP. External internet traffic is especially dangerous. Verify all internal traffic e.g. between load balancers, web servers or back-end systems.
- Is sensitive data stored in clear text, including backups?
- Are any old or weak cryptographic algorithms used either by default or in older code?
- Are default crypto keys in use, weak crypto keys generated or re-used, or is proper key management or rotation missing?
- Is encryption not enforced, e.g. are any user agent (browser) security directives or headers missing?
- Does the user agent (e.g. app, mail client) not verify if the received server certificate is valid?

- **Technical and business impact**

- Access to confidential data and possibility to amend it.

- **Legal implications**

- Cybersecurity legislation obligations, data protection obligations (security measures, access management, data minimization, need to know principle), commercial liability of IT security, specific regulatory provisions, criminal law angles

1 of 9: Correlation with information security - OWASP Top 10 risk - Security Logging and Monitoring Failures

- **Examples**

- Auditable events, such as logins, failed logins, and high-value transactions are not logged.
- Warnings and errors generate no, inadequate, or unclear log messages.
- Logs of applications and APIs are not monitored for suspicious activity.
- Logs are only stored locally.
- Appropriate alerting thresholds and response escalation processes are not in place or effective

- **Technical and business impact**

- Most successful attacks start with vulnerability probing. Allowing such probes to continue can raise the likelihood of successful exploit to nearly 100%. In 2022, identifying a breach took an average of 277 days – plenty of time for damage to be inflicted (according to IBM data breach report).

- **Legal implications**

- Cybersecurity legislation obligations, data protection obligations (minimization, access management, security measures, data breach notification), commercial liability of IT security.

1 of 9: Correlation with information security

Types of negative consequences for lack of compliance with data protection legislation:

- **Fines up to 4% of the worldwide turnover**
- Payment of prejudice incurred by individuals
- Payment of prejudice/costs incurred by co-contractors
- **Suspension or ceasing of the data processing**
- **Reputational impact**

1 of 9: Correlation with information security

France

- Lack of security measures for web application that lead to personal data (including ID cards) being publicly accessible (real estate company – EUR 400,000)
- Lack of proper **authentication method** (insurance company – EUR 180,000)

Norway

- Lack of security measures for **authentication** in mobile application (school – EUR 203,000)
- Lack of proper security measures for **authentication** (local authority – EUR 170,000)

Italy

- Lack of proper security measures on a web application of a data processor (online voting platform – EUR 50,000)

Lithuania

- Lack of security measures for web application (payment service provider – EUR 61,500)

UK

- Issues with security of web application (airline company – EUR 204.6 mil)
- Lack of proper assessment of IT system purchased and lack of implementation of security measures (hotel company – EUR 110.3 mil)

The Netherlands

- Lack of proper access management implementation (hospital – EUR 460,000)

Poland

- Lack of security measures implemented (online retail company – EUR 644,000)

1 of 9: Correlation with information security

Bulgaria

- Lack of proper security measures (fiscal authority – EUR 2.6mil)
- Lack of proper security measures for confidentiality of data, including ID cards and biometric data (bank – EUR 511,000)

Germany

- Lack of proper encryption in (social media company – EUR 20,000)

Malta

- Lack of proper security measures on a web application which led to data being publicly available (public authority – EUR 5,000)

Portugal

- Improper **access management** (hospital – EUR 400,000)

The Czech Republic

- Lack of proper security measures implemented (credit broker EUR 1,165)

<http://www.enforcementtracker.com/>

Romania

- Customer transaction **data available in clear text on the website** (law services company)
- Online accounts not having proper security measures implemented (online retail company)
- Lack of **encryption of data at rest** (police office)
- Lack of measures to ensure confidentiality and prevent unauthorized disclosure (fiscal authority)
- Lack of proper **policies and procedures** in place for ensuring confidentiality of data (retail company)

2 of 9: Data protection concepts: Personal data definition

- **any information**

- objective data about an individual (such as a client's job)
- subjective data about an individual (such as a client's risk rating).

- **related to a natural person**

- (a) pertaining to an **individual** (such as the car purchased through a leasing agreement)
- (b) has **an influence on or is influenced by an individual** (such as the predisposition to certain illness)
- (c) are in the **physical or geographical vicinity of an individual** or its objects (such as location of merchants where individuals usually shop in the evening, as this may refer indirectly to the home location of the individuals).

- that **identifies or makes identifiable** a natural person – e.g. groups of individuals

- either through data held by the controller or data that the controller may obtain – not clearly defined concept

Special types of personal data – article 9 GDPR – e.g. biometrics for identification, health data, criminal records, politic views.

2 of 9: Data protection concepts: Personal data definition

- EXERCISE – identify personal data (yes/no):
 1. IP address
 2. CNP – unique national identification number
 3. First and last name of an individual
 4. Primary key in a client database

[yes/no] – [reason why yes/no]

2 of 9: Data protection concepts: Personal data definition

- EXERCISE – identify personal data (yes/no):
 1. IP address – yes, if the exact individual can be identified or identifiable – e.g. a company for its employees as long as the allocation IPs are logged
 2. CNP – unique national identification number – yes, if the person having this information can CNP introduce in a database/excel/google search/etc to obtain
 3. First and last name of an individual – yes, if the name is uncommon and the individual can be identified having this information in a database/google search/etc; no, if the name is common and the user cannot be identified in a database/google search/etc
 4. Primary key in a client database – yes, if the person holding this information can lookup additional data about the individual by introducing the primary key in a database/excel/etc

2 of 9: Data protection concepts: Personal data definition

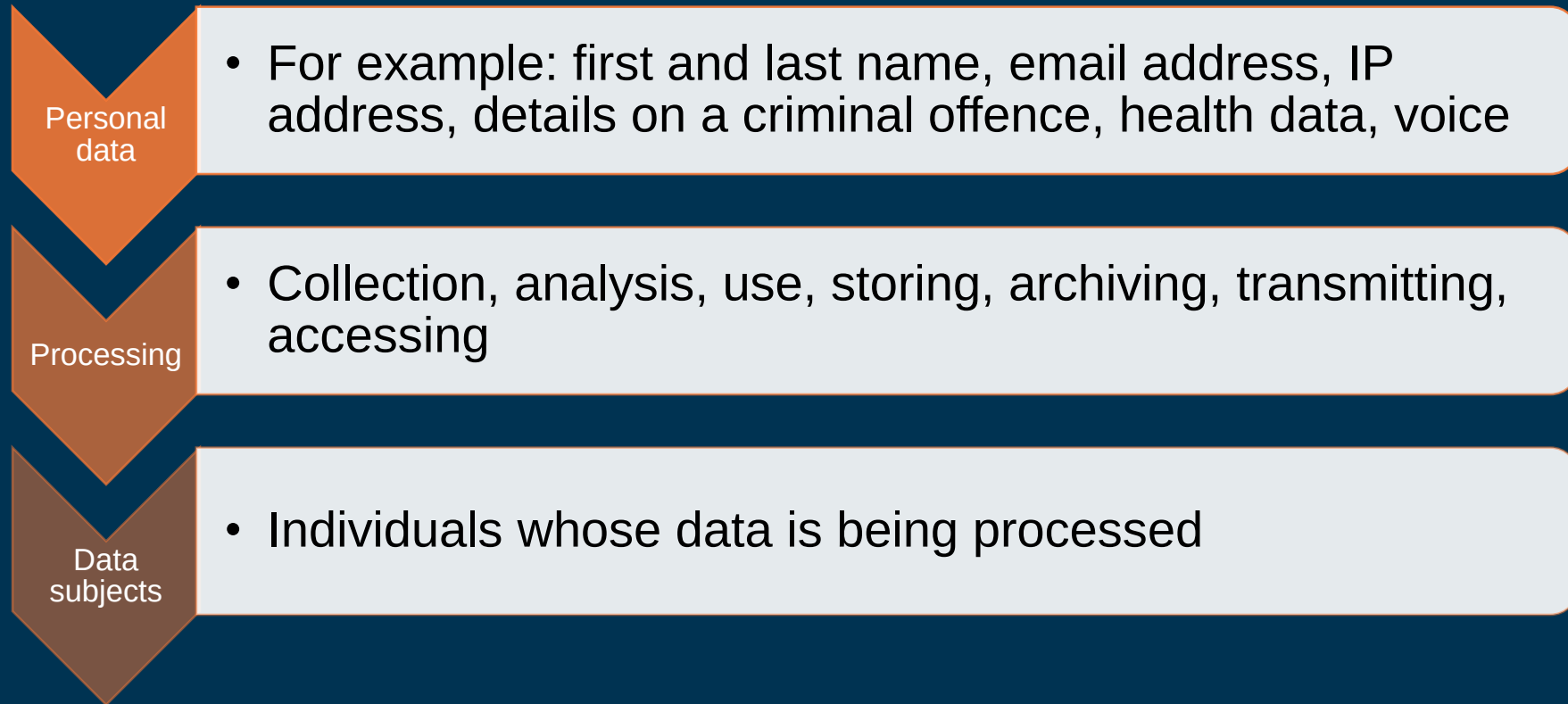
- Identify personal data:

1. **Logs of a web application** – yes, if they contain personal data that identifies or makes identifiable an individual
2. **Voice of client calling the call center of a company** – yes, if the calling IT system records the call and holds other information identifying the individual
3. **Predictions of diseases based on health app data** – yes, if the data in the health app identifies or makes identifiable an individual. Generally this is the case given the sign up information and location tracking.
4. **“Client 123 drinks coffee from the coffee shop on Street X each morning at exactly 8am”** – yes, if the client ID “123” can be introduced in a system and leads to the client being identified or if the other information in this statement can be searched in a database and lead to the client being identified or identifiable.
5. **Cookies** – yes, if the data held in the cookie is personal data identifying a visitor or makes the visitor identifiable

2 of 9: Data protection concepts: Personal data definition

- Identify personal data:
 1. **National ID card** – yes, there are sufficient data there to identify an individual
 2. **“team lead in the DevOps team in Bank A likes fast cars”** – yes, if the individual can be identified or a group of individuals being team lead in the DevOps team in Bank A can be identified – e.g. on social media
 3. **John Doe likes coffee** – no, as the name is too common
 4. **Video surveillance of entrance in a building** – no, if no face recognition exists; yes, if the recorded video is viewed by the police, etc to identify an individual they are looking for
 5. **“some students of ISM master programme like coffee”** – yes, if, for example, additional information about coffee is found on social media about an ISM master student

2 of 9: Data protection concepts: Data processing activity



- ✓ **Data processing purpose** identification as basis for analysis. Example: internet banking app having multiple data flows – making payments, obtaining loans, shopping in the market place for partner products, obtaining insurance.

2 of 9: Data protection concepts: Data processing activity

Storing in the cloud or on a co-contractor's server – relevant aspects to analyse

- **Location of data on the primary server**
- **Location of all replications, transiting data and back-ups**
- **Location of data processed by sub-contractors of the hosting entity**
- **Collection of metadata or telemetry data**
- **Further analysis if data outside the EU - main points:**
 - If decision about adequate level of protection of personal data – issued by the EC
 - If binding corporate rules (transfer within an organisation having locations in countries outside the EU)
 - If standard model clauses (agreement with hosting entity based on EC template) + supplementary measures for protection of personal data

2 of 9: Data processing activities - Exercise

Identify the data processing activities:

- ✓ Insurance company (Insurance Inc)
- ✓ It already has an application used by its customers (for contracts, new products) and non-customers (filing requests for offers)
- ✓ For vehicle insurances, the app contains data from sensors on the smart vehicles of the clients (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state)
- ✓ The app is hosted with its developer (DevOps Inc)
- ✓ DevOps Inc performs maintenance services and bug fixing
- ✓ It sends the data to a bank within the same group as the insurance company for credit scoring

2. Who are the data subjects?
3. What personal data is processed?
4. How is the data processed?

1. Who processes the personal data?

2 of 9: Data processing activities - Exercise

Identify the data processing activities:

- ✓ Insurance company (Insurance Inc)
- ✓ It already has an application used by its customers (for contracts, new products) and non-customers (filing requests for offers)
- ✓ For vehicle insurances, the app contains data from sensors on the smart vehicles of the clients (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state)
- ✓ The app is hosted with its developer (DevOps Inc)
- ✓ DevOps Inc performs maintenance services and bug fixing
- ✓ It sends the data to a bank within the same group as the insurance company for credit scoring

1. Who processes the personal data?

Client actions in the client app data processing: The insurance company (Insurance Inc) and the app developer (DevOps Inc)

Vehicle monitoring data processing: The insurance company and the app developer (DevOps Inc)

Credit scoring: Bank

2. Who are the data subjects?

3. What personal data is processed?

4. How is the data processed?

2 of 9: Data processing activities - Exercise

Identify the data processing activities:

- ✓ Insurance company (Insurance Inc)
- ✓ It already has an application used by its customers (for contracts, new products) and non-customers (filing requests for offers)
- ✓ For vehicle insurances, the app contains data from sensors on the smart vehicles of the clients (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state)
- ✓ The app is hosted with its developer (DevOps Inc)
- ✓ DevOps Inc performs maintenance services and bug fixing
- ✓ It sends the data to a bank within the same group as the insurance company for credit scoring

1. Who processes the personal data?

Client actions in the client app data processing: The insurance company (Insurance Inc) and the app developer (DevOps Inc)

Vehicle monitoring data processing: The insurance company and the app developer (DevOps Inc)

Credit scoring: Bank

2. Who are the data subjects?

Client actions in the client app data processing: the clients and potential clients of Insurance Inc

Vehicle monitoring data processing: The clients of the insurance company (if they are individuals), the drivers of the vehicles (if the clients are legal entities or if someone else is driving aside from the clients)

Credit scoring: clients of Insurance Inc

3. What personal data is processed?

4. How is the data processed?

2 of 9: Data processing activities - Exercise

Identify the data processing activities:

- ✓ Insurance company (Insurance Inc)
- ✓ It already has an application used by its customers (for contracts, new products) and non-customers (filing requests for offers)
- ✓ For vehicle insurances, the app contains data from sensors on the smart vehicles of the clients (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state)
- ✓ The app is hosted with its developer (DevOps Inc)
- ✓ DevOps Inc performs maintenance services and bug fixing
- ✓ It sends the data to a bank within the same group as the insurance company for credit scoring

1. Who processes the personal data?

Client actions in the client app data processing: The insurance company (Insurance Inc) and the app developer (DevOps Inc)

Vehicle monitoring data processing: The insurance company and the app developer (DevOps Inc)

Credit scoring: Bank

2. Who are the data subjects?

Client actions in the client app data processing: the clients and potential clients of Insurance Inc

Vehicle monitoring data processing: The clients of the insurance company (if they are individuals), the drivers of the vehicles (if the clients are legal entities or if someone else is driving aside from the clients)

Credit scoring: clients of Insurance Inc

3. What personal data is processed?

Client actions in the client app data processing: identification data, insurance contract data, insurance claims data

Vehicle monitoring data processing: location data, metadata on driving manner (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state), client data

Credit scoring: identification data, insurance contract data, insurance claims data, location data, metadata on driving manner

4. How is the data processed?

2 of 9: Data processing activities - Exercise

Identify the data processing activities:

- ✓ Insurance company (Insurance Inc)
- ✓ It already has an application used by its customers (for contracts, new products) and non-customers (filing requests for offers)
- ✓ For vehicle insurances, the app contains data from sensors on the smart vehicles of the clients (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state)
- ✓ The app is hosted with its developer (DevOps Inc)
- ✓ DevOps Inc performs maintenance services and bug fixing
- ✓ It sends the data to a bank within the same group as the insurance company for credit scoring

1. Who processes the personal data?

Client actions in the client app data processing: The insurance company (Insurance Inc) and the app developer (DevOps Inc)

Vehicle monitoring data processing: The insurance company and the app developer (DevOps Inc)

Credit scoring: Bank

2. Who are the data subjects?

Client actions in the client app data processing: the clients and potential clients of Insurance Inc

Vehicle monitoring data processing: The clients of the insurance company (if they are individuals), the drivers of the vehicles (if the clients are legal entities or if someone else is driving aside from the clients)

Credit scoring: clients of Insurance Inc

3. What personal data is processed?

Client actions in the client app data processing: identification data, insurance contract data, insurance claims data

Vehicle monitoring data processing: location data, metadata on driving manner (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state), client data

Credit scoring: identification data, insurance contract data, insurance claims data, location data, metadata on driving manner

4. How is the data processed?

Client actions in the client app data processing: collection, storing, analysis, transfer, deletion

Vehicle monitoring data processing: collection, storing, analysis, deletion, transfer

Credit scoring: collection(indirectly), storing, analysis, deletion

3 of 9: Processing basis

Main types of processing basis usually applicable (other types are listed under article 6 of GDPR):

- Performance of agreement with the data subject (including negotiation phase)
- Legal obligation of the data controller (not of anyone else) – e.g. registration with authorities, reporting
- Legitimate interest of a data controller
- Consent (expressly given, freely given, informed, easily accessible, plain language)

- For **subsequent data processing (different purposes)**, separate analysis should be made.

Examples:

1. data initially processed for usage of travel app used for identifying bugs and improving app;
2. user data used subsequently for marketing towards the users

Compatibility test:

- **Similarity** between the initial and subsequent purpose
- **Reasonable expectation** of the data subject with respect to the subsequent purpose
- **Types of personal data** processed and the **consequences** of the processing on the data subject
- Measures implemented for **preventing negative consequences** on data subjects

***Intra-group transfers** – analysis of legal basis every time. Including in cases where a company holds IT apps/infrastructure for entire group

3 of 9: Processing basis

For the use case:

- ✓ Insurance company (Insurance Inc)
- ✓ It already has an application used by its customers (for contracts, new products) and non-customers (filing requests for offers)
- ✓ For vehicle insurances, the app contains data from sensors on the smart vehicles of the clients (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state)
- ✓ The app is hosted with its developer (DevOps Inc)
- ✓ DevOps Inc performs maintenance services and bug fixing
- ✓ It sends the data to a bank within the same group as the insurance company for credit scoring
- ✓ It obtains data from a credit scoring agency for its potential clients
- ✓ It obtains leads from an e-commerce website (name, telephone number and email address)
- ✓ It sends annual reports to its supervisory authority

What is the processing basis for each processing activity?

3 of 9: Processing basis

For the use case:

- ✓ Insurance company (Insurance Inc)
- ✓ It already has an application used by its customers (for contracts, new products) and non-customers (filing requests for offers)
- ✓ For vehicle insurances, the app contains data from sensors on the smart vehicles of the clients (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state)
- ✓ The app is hosted with its developer (DevOps Inc)
- ✓ DevOps Inc performs maintenance services and bug fixing
- ✓ It sends the data to a bank within the same group as the insurance company for credit scoring
- ✓ It obtains data from a credit scoring agency for its potential clients
- ✓ It obtains leads from an e-commerce website (name, telephone number and email address)
- ✓ It sends annual reports to its supervisory authority

What is the processing basis for each processing activity performed by a data controller?

Processing activities:

Insurance services:

Vehicle monitoring to prevent stealing:

Vehicle monitoring for insurance policy tailoring:

Credit scoring for bank:

Credit scoring for Insurance Inc.:

Lead collection from e-commerce website:

Reports to authority:

3 of 9: Processing basis

For the use case:

- ✓ Insurance company (Insurance Inc)
- ✓ It already has an application used by its customers (for contracts, new products) and non-customers (filing requests for offers)
- ✓ For vehicle insurances, the app contains data from sensors on the smart vehicles of the clients (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state)
- ✓ The app is hosted with its developer (DevOps Inc)
- ✓ DevOps Inc performs maintenance services and bug fixing
- ✓ It sends the data to a bank within the same group as the insurance company for credit scoring
- ✓ It obtains data from a credit scoring agency for its potential clients
- ✓ It obtains leads from an e-commerce website (name, telephone number and email address)
- ✓ It sends annual reports to its supervisory authority

What is the processing basis for each processing activity performed by a data controller?

Insurance services: performance of agreement
Vehicle monitoring to prevent stealing: legitimate interest
Vehicle monitoring for insurance policy tailoring: consent
Credit scoring for bank: consent
Credit scoring for Insurance Inc.: it depends; could be consent or legitimate interest
Lead collection from e-commerce website: consent
Reports to authority: legal obligation

4 of 9: Data controller vs. data processor - Key characteristics

- **Controller**

- Entity which (alone or together with others); when jointly with others => joint controllers
- Determines the purposes; and
- Determines the means of processing.

- **Processor**

- Entity processing personal data on behalf of the controller; and
- Acting as per the instructions of the controller.

Examples:

- ✓ **IT maintenance services** – generally, processor, as it receives instructions from its clients on how to handle the data
- ✓ **Lawyer in a law firm** – controller, as the lawyer acts upon its specific legislation and code of conduct, thus determining the purpose and means of processing
- ✓ **Cloud service provider offering storage** – processor, as it receives instructions from its client on how to handle the data
- ✓ **Company offering SOC services** (incident monitoring and analysis) – generally, processor, as it receives instructions from its client on how to handle the data
- ✓ **IT development services** – generally, for providing this type of service, access to personal data should not exist, except for specific situations. If personal data is processed, processor, as it receives instructions on how to handle the data from the beneficiary of the development services

4 of 9: Data controller vs. data processor

On-premises	IaaS	PaaS	SaaS
Applications	Applications	Applications	Applications
Data	Data	Data	Data
Runtime	Runtime	Runtime	Runtime
Middleware	Middleware	Middleware	Middleware
OS	OS	OS	OS
Virtualization	Virtualization	Virtualization	Virtualization
Servers	Servers	Servers	Servers
Storage	Storage	Storage	Storage
Networking	Networking	Networking	Networking

4 of 9: Data controller vs. data processor

- Insurance company (Insurance Inc)
- It already has an application used by its customers (for contracts, new products) and non-customers (filing requests for offers)
- For vehicle insurances, the app contains data from sensors on the smart vehicles of the clients (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state)
- The app is hosted with its developer (DevOps Inc)
- DevOps Inc performs maintenance services and bug fixing
- It sends the data to a bank within the same group as the insurance company for credit scoring
- It obtains data from a credit scoring agency for its potential clients
- It obtains leads from an e-commerce website (name, telephone number and email address)
- It sends annual reports to its supervisory authority
- It performs profiling of its clients holding a vehicle insurance through machines learning algorithms, especially based on the manner in which they drive (sensors within the smart car). This is used to adjust the amount of insurance premium that individual has to pay. Company GoodProfiling Inc is used for this activity.

What are the roles (data controller or data processor) for each entity mentioned for each data processing it performs

4 of 9: Data controller vs. data processor

- Insurance company (Insurance Inc)
- It already has an application used by its customers (for contracts, new products) and non-customers (filing requests for offers)
- For vehicle insurances, the app contains data from sensors on the smart vehicles of the clients (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state)
- The app is hosted with its developer (DevOps Inc)
- DevOps Inc performs maintenance services and bug fixing
- It sends the data to a bank within the same group as the insurance company for credit scoring
- It obtains data from a credit scoring agency for its potential clients
- It obtains leads from an e-commerce website (name, telephone number and email address)
- It sends annual reports to its supervisory authority
- It performs profiling of its clients holding a vehicle insurance through machines learning algorithms, especially based on the manner in which they drive (sensors within the smart car). This is used to adjust the amount of insurance premium that individual has to pay. Company GoodProfiling Inc is used for this activity.

What are the roles (data controller or data processor) for each entity mentioned for each data processing it performs

Insurance services:

Maintenance of app:

Vehicle monitoring to prevent stealing:

Vehicle monitoring for insurance policy tailoring:

Credit scoring for bank:

Credit scoring for Insurance Inc.:

Lead collection from e-commerce website:

Reports to authority:

4 of 9: Data controller vs. data processor

- Insurance company (Insurance Inc)
- It already has an application used by its customers (for contracts, new products) and non-customers (filing requests for offers)
- For vehicle insurances, the app contains data from sensors on the smart vehicles of the clients (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state)
- The app is hosted with its developer (DevOps Inc)
- DevOps Inc performs maintenance services and bug fixing
- It sends the data to a bank within the same group as the insurance company for credit scoring
- It obtains data from a credit scoring agency for its potential clients
- It obtains leads from an e-commerce website (name, telephone number and email address)
- It sends annual reports to its supervisory authority
- It performs profiling of its clients holding a vehicle insurance through machines learning algorithms, especially based on the manner in which they drive (sensors within the smart car). This is used to adjust the amount of insurance premium that individual has to pay. Company GoodProfiling Inc is used for this activity.

What are the roles (data controller or data processor) for each entity mentioned for each data processing it performs

Insurance services: Insurance Inc – controller

Maintenance of app: DevOps Inc - processor

Vehicle monitoring to prevent stealing: Insurance Inc – controller

Vehicle monitoring for insurance policy tailoring: Insurance Inc – controller; GoodProfiling Inc – processor (in general)

Credit scoring for bank: Insurance Inc – controller; bank - controller

Credit scoring for Insurance Inc.: Insurance Inc – controller; credit scoring agency – controller

Lead collection from e-commerce website: Insurance Inc – controller; e-commerce website - controller

Reports to authority: Insurance Inc – controller; authority - controller

4 of 9: Controller vs. processor

Case study 1 of 2

- **Recruitment agency**

- Who establishes the **purpose**?

Depends; if the recruitment agency receives from the company a list of characteristics for the candidates, identified the candidates through various means

If the recruitment agency receives the CVs of the candidates from the company or very specific instructions on identifying the candidates directly, it may be qualified as a data processor

- Who sets-out the **means**?

Depends; generally, if the recruitment agency is a data controller, it also establishes the software it uses, means of transfer of data, storing of data, etc

If the recruitment agency is a data processor (less likely in practice), the controller would generally set out the means of processing.

4 of 9: Controller vs. processor

Case study 2 of 2

- **Web application created together by a travel agency, a hotel and an airline**
 - Who establishes the **purpose**? – all three entities
 - Who sets-out the **means**? – generally, all three entities
 - Who holds the **data**? – generally, it may be considered that the data is held by an entity on behalf of all three entities
 - Who has **direct access to the data**? – generally, all three entities

Thus, the three entities act as joint data controllers

5 of 9: Liability sharing

- Types of **potential claims** to be brought:
 - Penalties from authorities
 - Claims from data subjects
 - Claims from co-contractors
- Protection against payment of claims:
 - **Contractual limitation** of amount to be paid for liability
 - **Exclusion of liability** in certain specific situations listed in the agreement
 - **Limitation on costs incurred** for assistance to the co-contractor, especially in court proceedings or when addressing data subject requests
 - Recital 78 GDPR – detailing the obligation to implement **privacy by design**

5 of 9: Liability sharing

Case study

- **GPS tracking of car fleet**

(using third party software off the shelf hosted by the third party vendor, with a certain level of maintenance services)

Important questions to ask

- **Who has access to data?** Access management and proper logging thereof is important in case of a data breach and when assigning liability
- **Who runs the reports?** Access management and proper logging thereof is important in case of a data breach and when assigning liability
- **Where is the server located?** The entity holding the server will generally be responsible to implement security measures. The location of the server (EU/non-EU) may lead to liability on the side of the data controller (if it did not verify/take appropriate steps) or on the side of the data processor (GPS service provider) if it moved data outside of the EU without letting the data controller know, for example.
- **Build-in opt-out for employees when off-work?** This is a privacy ensuring mechanism usually built-into the GPS tracker. It should be requested by the data controller. Lack of such mechanism may lead to damages being requested by individuals from the data controller.
- **Privacy by design obligation for software developer?** Generally, yes. Nevertheless, the data controller is also responsible for choosing appropriate software having proper privacy mechanisms in place.

In case of a data breach on the server where the software is stored, who is liable? Explain why.

Depends on the contract. Generally, if the data breach occurred with the GPS service provider (who also stored the tracking data) because of a lack of proper security measure implementation by the GPS service provider, the GPS service provider is liable towards the individuals affected.

6 of 9: Information notices (Transparency principle)

- **Clear, concise**, complete, layer approach/entire information notice
- **Evidence** needed for being brought to the attention of the data subject – e.g. tick boxes saved in the database
- Specific content – articles 13 and 14 of the GDPR
- **Easily accessible** for users when online (direct access or layered approach)
- Provided **prior to any data processing** takes place (with some exemptions)

7 of 9: Data subject rights and retention period

- Focus on **right of erasure** and **right of access** – need to implement technical possibilities to address individual's rights when they file a request in this respect; anonymisation instead of deletion (see Working Party Article 29 opinion on anonymisation on Sakai)
- **Data minimisation principle** (limitation of types of personal data and of processing period) – in this case **limited retention period** based on the need to process data
- Implementation of deletion mechanism: automated or manual (correlated with other IT systems)
- **Data portability/data access** – legacy systems? Redundancy within systems?
- Structured and unstructured data
- Propagation throughout the IT systems
- Know your architecture; know your data – call center example

8 of 9: Profiling and automated decisions

Concept

Profiling represents:

- any form of automated processing of personal data
- used to evaluate (including to analyse or to predict) certain personal aspects relating to a natural person

Limitations to profiling: e.g. need for consent in case of intrusive profiling (such as, processing of data not expected by data subject, which can cause harm to the data subject or discriminate him/her)

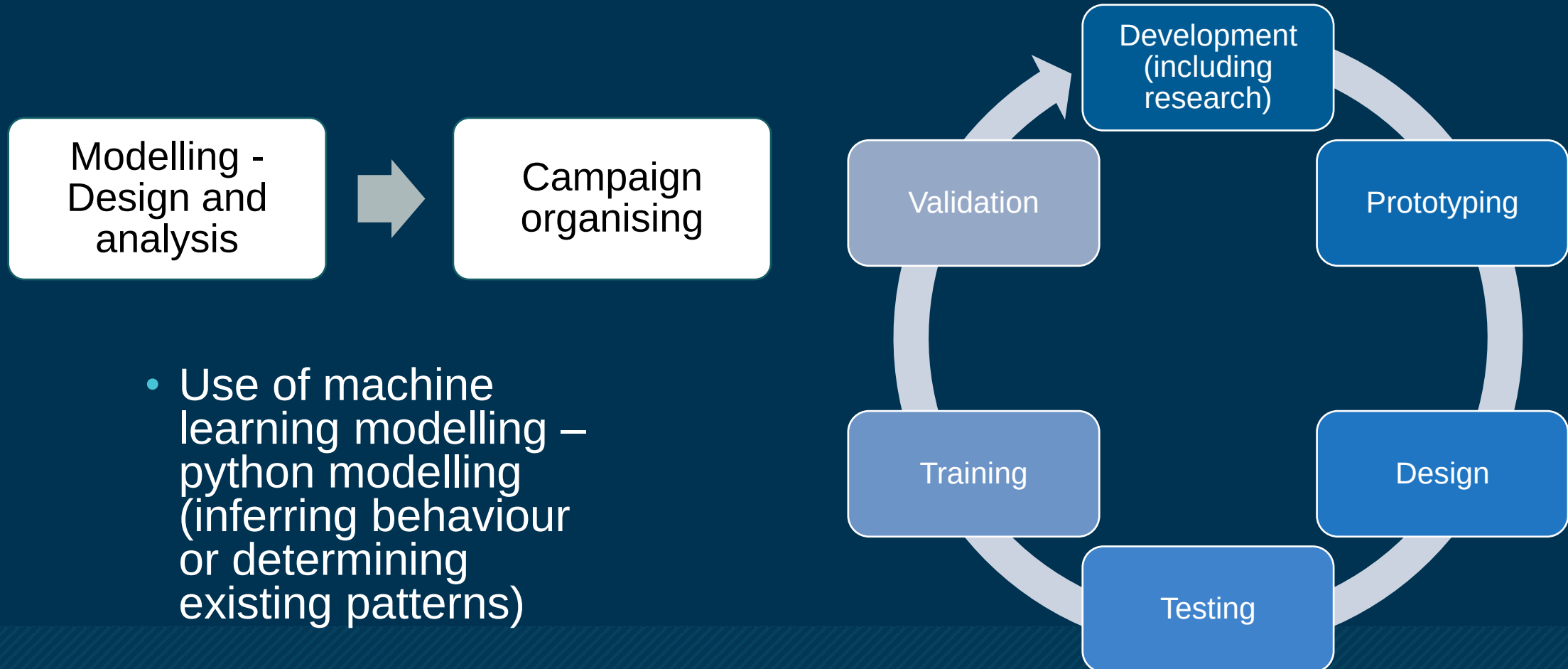
Limitations for automated decisions:

- a decision to be taken solely on automated processing (including profiling); and
- the decision to produce legal effects concerning him or her or similarly significant affects him.

Exemptions to limitations for automated decisions:

- necessity for a contract; or
- authorised by the law of EU or member states; or
- explicit consent of data subject.

8 of 9: Profiling - Data analytics for marketing purposes



8 of 9: Profiling: Use of third parties for analytics

- Controller vs processor
 - Third party used for development/training/validation of the model
 - Third party giving data to the organisation for analysis by the organisation
- Who decides the **purpose and the data to be used** for training?
- How **granular does a purpose** have to be established for an entity to become controller?
- Is it relevant **where the data was collected from and by whom?**

8 of 9: Profiling and automated decisions

Potential risks

- Discrimination or unfair treatment
- Limits rights or denies an opportunity
- Biased/harms (CNIL, Solove, no receiving same offers)
- Lack of predictability
- Certain sectors of society may not be represented
- Jeopardize of data accuracy
- Data broking

Example: **Social media app** – using profiles of its users for marketing purposes (on behalf of other companies – e.g. banks, retail stores)

8 of 9: Profiling and automated decisions

To do list

- ❑ Data minimization – proportionality principle
- ❑ Accuracy of data stored
- ❑ Anonymisation/Pseudonymation
- ❑ Retention period
- ❑ Information provided to data subjects – including structuring of the profiling and envisaged consequences of such processing
- ❑ Right to rectification
- ❑ Right to object (specifics for marketing activities)
- ❑ Implementing appropriate safeguards
- ❑ Data protection impact assessment (data analysis specific in certain situations provided by law)
- ❑ AI ethics – new direction – EU reports; Global Privacy Assembly working group report

Example: **Social media app** – using profiles of its users for marketing purposes (on behalf of other companies – e.g. banks, retail stores)

8 of 9 Profiling: Anonymisation/Pseudonymisation

Technique/Risks	Singling-out risk (identifying all data pertaining to an individual)	Linkage risk (link data from various sources)	Inference risk (inferred data from multiple sources may lead to identification)
Pseudonymisation (replacing one attribute (typically a unique attribute) in a record by another)	Yes	Yes	Yes
Noise addition (randomisation technique that modifies the value of attributes in a dataset in such a manner in order to make this value less accurate, while maintaining the overall distribution)	Yes	Maybe	Maybe
Substitution (randomisation technique)	Yes	Yes	Maybe
k-anonymity (generalisation technique under which attributes are suppressed or generalized until each row is identical with at least k-1 other rows)	No	Yes	Yes
l-diversity (generalisation technique that builds on k-anonymity, ensuring that within each equivalence class created by k-anonymity, every attribute has at least l different values)	No	Yes	Maybe
Differential privacy (generalisation technique that only releases for analysis (including by third parties) sub-sets of data (based on specific queries applied to the initial dataset) which have been anonymised based on the other techniques)	Maybe	Maybe	Maybe
Pseudonymisation through hashing/tokenisation	Yes	Yes	Maybe

9 of 9: Pseudo-anonymized data - Case study

- **Database of financial transactions from a bank account**

(pseudo-anonymization of such data)

- Limitations around the use for creating new products or for marketing campaigns
- (i) it is still possible to identify a data subject? (ii) it is still possible to link records/entries relating to the same data subject? or (iii) information can be deduced/inferred regarding a data subject?
- Is the data subject identified or identifiable by using any means likely reasonable to be used by either a data controller or a third party?

How you would approach pseudo-anonymisation of financial transactions from the bank account of an individual in order to keep them relevant for data analytics? Think of the types of data included in your bank statement.

Relevant legislation and guidance

- GDPR (EU Regulation 2016/679)
- Law no. 190/2018
- Law no. 506/2004
- Working Party Article 29 guidance
- EDPB guidance
- OASIS – privacy by design guidance for engineers
- ISO/IEC 29134 – data protection impact assessment
- ISO/IEC 27701 – data protection management
- NIST 800-37 – security and data protection risk assessment
- NIST 800-53 – security and data protection controls
- NIST privacy framework – draft
- AICPA/GAPP- methodology for privacy maturity assessment
- OECD 108 Convention for the Protection of Individuals with regard to Automatic Processing of Personal Data



Questions?

Email: larisagabudeanu@gmail.com